

Designing Backup Governance at Scale: Meeting APRA CPS234 Segregation of Duty Across a Hybrid Cloud Estate

Executive Summary

Five petabytes of regulated data across 350+ AWS accounts and Azure subscriptions at one of Australia's largest Tier 1 financial institutions were brought into APRA CPS 234 compliance through a purpose-built backup governance architecture – enforcing segregation of duty at scale without disrupting application team recovery workflows.

Architectural challenges included a clean separation of centralised control plane to provide an exclusive ownership to backup administrators, which would be leveraged for backup policy, retention, encryption key, and onboarding lifecycles without changing self-service recoverability workflow. The solution needed cost effective, scalable, secure and reliable design which is deliverable within the timeline that would fill the current backup gaps. One solution did not fit 100% of the accounts, given a diverse nature of dataset and workloads.

AWS and Azure native backup services were chosen as a default path with exceptional scenarios to be fulfilled with Commvault, replication and in-place protection.

Context and Regulatory Trigger

CPS 234 and CPG 234 mandate that data backups are classified as critical information assets, requiring controls for protection and recovery. [APRA](#) specifically highlights that segregation of duties must prevent any single user from controlling both production data and backups to mitigate ransomware risks. For more information, visit [APRA](#).

One of Australia's largest Tier 1 financial institutions with thousands of workloads spanning data centres, SaaS, and public cloud, faced a mandatory compliance deadline across its entire backup estate. It was a CTO level priority, with backups within 350+ accounts and subscriptions across AWS and Azure to be protected with Segregation of Duty (SoD).

The architecture mandate was to meet CPS234 SoD requirements across the full cloud estate without disrupting workload team autonomy or breaking existing recovery workflows.

The Problem Statement

Historically, the institution had fragmented and ungoverned backup estate where each application's owner would administer their own backups and snapshots along with the

policies thereof. While there was one central team managing / governing system of records backups as per the organisational policy, they lacked any controls / governance over other datasets.

With landing zone ownerships and RBAC in place, an account admin could destroy backups from the same control plane as the workload, making any IAM tightening insufficient. The account admin could change backup policies, delete vaults, snapshots, recovery points etc. Further, organisation data were at risk where a ransomware playbook would destroy the backup first before encrypting production (Once an account is compromised).

The Status Quo failed to meet the CPS234 requirements.

There was a need for a clear separation of backup control plane from backup dataplane where control plane access would remain exclusively with a central Backup and Recovery (CBT) team with ability to onboard/offboard, audit, policy management and monitor backups/recovery.

Options assessed

Four options were assessed anchored to the well architected framework, organisational structure and the organisational need to protect the backups via SoD.

Primary Well Architected pillars were security and reliability. An option is stronger where both pillars are strongly justified against the requirements, with other (secondary) pillars such as cost, performance efficiency and operational excellence under consideration for the options' ranking.

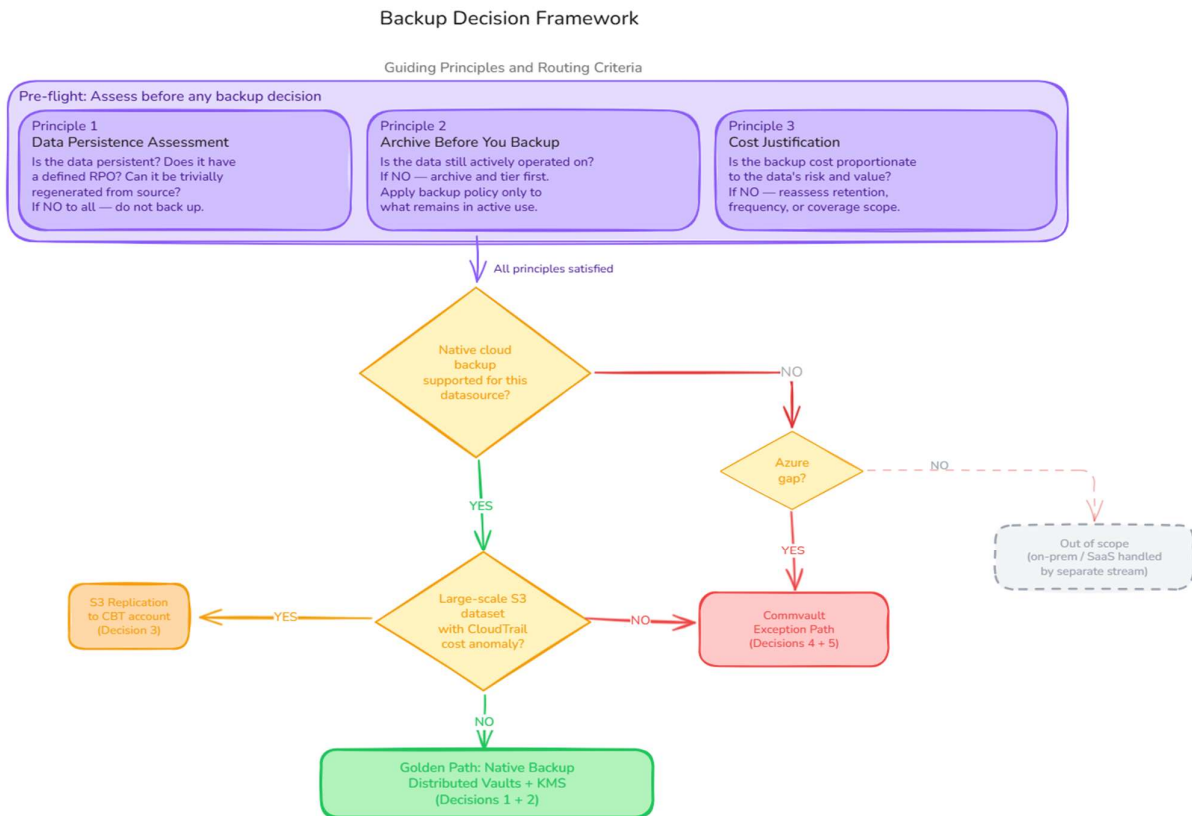
With this mindset, a clear winner – native backup / recovery services – emerged, meeting security and reliability requirements at scale given their control and data plane features. On top of meeting the primary requirements, it also met the requirements for performance efficiency and operational excellence at scale. There were a few exceptional scenarios where cost and performance were debatable due to large-scale datasets, alternative options were considered without compromising on primary pillars. In these situations, exceptions were formally documented, reviewed with stakeholders, and approved by leadership before implementation. Following table summarises the options, pros and cons and their outcomes.

Option	Security and Reliability	Cost, Performance and Operational Excellence	Outcome/Recommendation
Don't change anything but revisit the access management of each backup.	With account / subscription owner has full control, nearly impossible to enforce consistency and security of backup instances.	Expensive to manage granular IAM with poor visibility and auditability.	The option failed to meet requirements on primary pillars of security and reliability. Result: Not recommended

Use centrally managed and governed Commvault	Secure and Reliable with a caveat that the deployment infrastructure itself needed an alternate architecture. The only problem with its infrastructure deployment was that Commvault's infrastructure sat in the same management group inheritance path as workload admins, meaning an attacker with elevated production credentials could reach the backup infrastructure. The product itself was industry proven on security and reliability.	Operational complexity was arguably minimal since the Commvault was already operational for selected applications. Performance at scale with 350+ accounts is impacted with limitations on backup frequencies and time-consuming recoverability. Significant additional cost for data storage, data egress, infrastructure scaling and Licensing cost at scale.	While it's quite secure and reliable way to backup, additional cost for backing up 350+ accounts and subscriptions were more than 10 times along with resulting poor backup and recovery performance. Result: One of the possible options. Retained only as an exception for specific datasource gaps.
Use data replication to a secure account technique	The security boundary is achievable but at the cost of operational complexity that's unmanageable at hundreds of accounts, and async replication creates recovery time implications.	Operationally, hard to enforce replications across 100s of datasources into one secure account at scale. Asynchronous replication creates recovery complexity, and at hundreds of accounts the operational enforcement overhead is unmanageable.	With achievable security and reliability, this option could be considered with a caveat of increasing cost and complexity at scale. Result: One of the possible options where the default option has a gap.
Native backup / BCDR	With vaulted backup and its operational control features, along with easy onboarding and offboarding at scale, this satisfied the necessary requirements immediately.	Easy to operate with enforcement, onboarding, offboarding, auditing, monitoring. Natively supporting datasources with scalable backup and quick recovery. Additional costs to be considered.	This is considered the best "Golden Path", i.e. this option is the default, policy-enforced approach across all accounts. Workloads may only deviate with documented exception approval supporting organizational requirements. Additional effort and cost incurred needed to be carefully assessed along with the trade-offs with remediated risks and other WAR pillars. Result: Chosen as a default approach for backups.

Architectural Decisions

Before any backup decision, three principles were assessed: data persistency, archival status, and cost justification. Only datasources satisfying all three pre-conditions were routed through the decision framework below. A default approach of native backup was taken unless a specific exception condition was met. The criteria can be summarised with the flowchart below.



Decision 1: Native Backup with distributed vaults

Background:

AWS and Azure backup service provides features like central tag-based onboarding, centralised policy/plan management against each datasource, auditing, monitoring along with vaulted backups. These “vaults” are specific resources created as part of the backup service.

The choice of vault topology determines the blast radius of any compromise and the operational complexity of the control plane. It was the first architectural question after the golden path was selected

Options considered:

- Centralised vaulted account.
- Distributed and centralised backup account.
- Distributed vaults -PREFERRED

Rationale:

Option a: High blast radius with one accident / account compromise will impact hundreds of workloads and critical business processes.

Option b: It's considered a target state with respect to 3-2-1 backup where centralised vault backup is considered a bunker ("A last resort"). It can act as a future airgapped backup solution. It could not be achieved with current scope and budget.

Option c: Distributed vaults mean a compromise of any single account affects only that account's backup recovery points, not the entire estate. The control plane remains centralised (CBT team governs policies, locks, and key rotation) while the data plane is distributed. With a clear control plane features to control and govern backups and policies, this was the preferred option.

Implications / impact:

- Changes in infrastructure as code for account creation to create a vault with policies.
- Changes in org policy on who can govern vault and its locks.
- Changes in account decommissioning procedure to have an additional dependency on central team to delete recovery points and vaults as needed.
- Workloads backups secured per CPS234 requirements.
- SoD was achieved without breaking the recovery workflow for application teams.

Decision 2: Native Backup with distributed KMS keys

Background:

Vaulted backups are to be encrypted by design of the service. With organisational security policy in place, it had to be customer managed KMS key. Choice of a centralised key management vs distributed keys, setting the right key policies in place to meet the requirement would dictate the blast radius and impact of a compromise. If a centrally managed key is compromised, tampered with, deleted, none of the backups would be recoverable.

Options considered:

- a. Centralised Key management, using same or different keys across all accounts and datasources.
- b. Distributed KMS within different accounts and datasources with governed key resource policies, without impacting "encrypt decrypt" operations by the individual account teams / resources. - PREFERRED

Rationale:

Option a: High blast radius with one accident / account compromise will impact hundreds of workloads and critical business processes. Compromising one set of keys within a single account will impact all the accounts.

Option b: With each account having its own set of KMS keys for their own vaults, disaster is contained.

Implications / impact:

- Changes in infrastructure as code for account creation to create a Keys for vaults with policies attached to them.
- Changes in org policy on who can govern KMS Keys, its delete / rotation policies.
- Workload teams retained self-service recovery access within their own accounts whereas SoD was achieved at the control plane without removing recovery autonomy at the data plane.
- Changes in account decommissioning process to request the central team to modify key delete policy and / or delete the key.

Decision 3: S3 cost anomaly - tactical response

Background:

While native backup approaches were being rolled out within AWS estate, a selected number of account owners complained about significant monthly increase in spend since onboarding to AWS backups (More than 8-10k AUD a month). On further investigation, it was found that this anomaly is coming from CloudTrail events that were emitted due to these accounts having S3 buckets with millions of objects (Some even approaching a billion). For each object backup, there were several API calls made, which contributed to a huge number of events and additional cost.

Options considered:

- a. Make an exception to the cloudtrail event logging for those buckets.
- b. Create continuous backups for those buckets which drastically minimise the number of API calls needed – sometimes in the excess of 10 times less - if the changes to objects are minimal.
- c. Use Commvault
- d. Use replication

Rationale:

Option a: It was thoroughly discussed with AWS team, and a product feature request was created immediately. They came up with a solution quickly to filter CloudTrail logs by role. However, this did not work at scale in the given environment since the postfix created by the backup service was changing and there was no way to filter with regex in the role ARN.

Option b: With continuous backup, the backup service will only create recovery points when an object is changed / deleted. It was found to be quite efficient. While it reduced the number of API calls, initial backup would still cost a significant amount. A combination of Option a and b was discussed but it was complex to manage the hard-coded ARN for cloudtrail filtering only for initial backup while making sure that subsequently the filter gets removed. It was a significant overhead to automate this new process.

Option c: Commvault was not cost and performance justified for S3 buckets of this scale.

Option d: Replication was the only viable option with respect to cost, operational and delivery viability. The destination account will be owned by CBT which will manage the bucket, policies and onboarding with accounts which fits these criteria.

Implications / impact:

- New architecture design.
- New process to justify a workload / datasource to be within this category.
- New guidance on how to manage and maintain the live hot data vs cold and archive dataset.
- Accounts with large dataset where backups were not cost justified with native backup services, were also secured.

Decision 4: Commvault exception path including infrastructure security fix

Background:

Central CBT team has been using Commvault for System of Record (SoR) backups aligning with organisational policy. During PoC evaluation of Azure native backup solutions with engineering team during Proof of Concept phase, it was figured there were several shortcomings: Blob backup required cross subscription replication turned on, PostgreSQL Flexi and Azure Files backup support was not GA'ed, SQL MI backup support was not planned, Azure Netapp Files had a separate backup vault not related to the Azure backup service.

These gaps, while escalated with Microsoft Azure team, there was no clear roadmap / timeline available and the risk of not meeting the compliance requirement was high. Therefore, an existing available backup approach with Commvault was taken as a tactical approach. During evaluation of Commvault deployment, it was found that it had been deployed within the same organisation unit / management group level across the clouds as other workloads. This would mean that an elevated principle could be used to destroy Commvault backup / infrastructure.

Options considered:

- a. Complete change in RBAC model.
- b. Use separate Azure Entra tenant for Commvault.
- c. Create a separate Management group for Commvault deployment. - PREFERRED

Rationale:

Option a: Change in RBAC model would be a big organisation wide impact, which would need a very detailed assessment. Besides, there is always a risk on existing workflow and applications being impacted, and additional user groups to be managed. This would not meet the timeline for compliance requirements.

Option b: This was the cleanest possible separation but would require additional overhead of cross tenant relationships, backups, monitoring, user maintenance etc. It would need highest level of leadership approval which was not practical.

Option c: A separate management group pattern was already created for AD related infrastructure. It was easy to make use of this pattern and create one in parallel, with dedicated ownership to the central CBT team.

Implications / impact:

- Any backups (SoR and Azure) were now meeting CPS234 requirements.
- New set of policies to be written, validated and applied to the new management group.
- Commvault infrastructure was now structurally isolated from workload admin credentials. An attacker with elevated access to production workloads could no longer reach the backup infrastructure through management group inheritance.

Decision 5: MUA (Multi-User Authorisation)

Background:

On Azure, even with Commvault isolated in a separate management group, certain destructive vault operations remained possible for anyone with sufficient role elevation – specifically, deleting or modifying backup vaults and recovery points. Multi-User Authorisation (MUA) adds a second approval gate: destructive operations on protected resources require approval from a designated Resource Guard, which sits under separate ownership from the backup infrastructure itself. This was the final layer needed to structurally enforce SoD at the Azure control plane level.

In fact, this was a target state for Azure based backup protection – whether through Commvault or native – it would guard the protected resource. In either scenario (With native or with Commvault), vault-based backups would be protected via Resource Guard's MUA.

On AWS, the equivalent structural control was achieved through Vault Lock in governance mode combined with SCP-enforced restrictions on vault policy modification - both implemented in Decision 1. MUA addresses the remaining gap on the Azure side

Options considered:

- a. Relying on RBAC and management group separation alone - the management group fix (Decision 4) addressed the inheritance path problem, but a sufficiently privileged identity could still perform destructive operations without a second approver.
- b. Implement MUA with Resource Guard under CBT ownership — PREFERRED

Rationale:

Option a: Insufficient as standalone control. Management group separation reduces the attack surface but does not require dual approval for destructive operations. Under CPS234, a single-actor control model is non-compliant regardless of how well the RBAC is structured.

Option b: Resource Guard is a native Azure feature that wraps protected operations (delete backup instance, delete vault, modify policy, disable soft delete) with a mandatory approval gate from a resource owned by a different identity than the backup operator. CBT owns the Resource Guard; backup operators cannot approve of their own destructive operations. This is the structural SoD control CPS234 requires at the Azure control plane.

Implications:

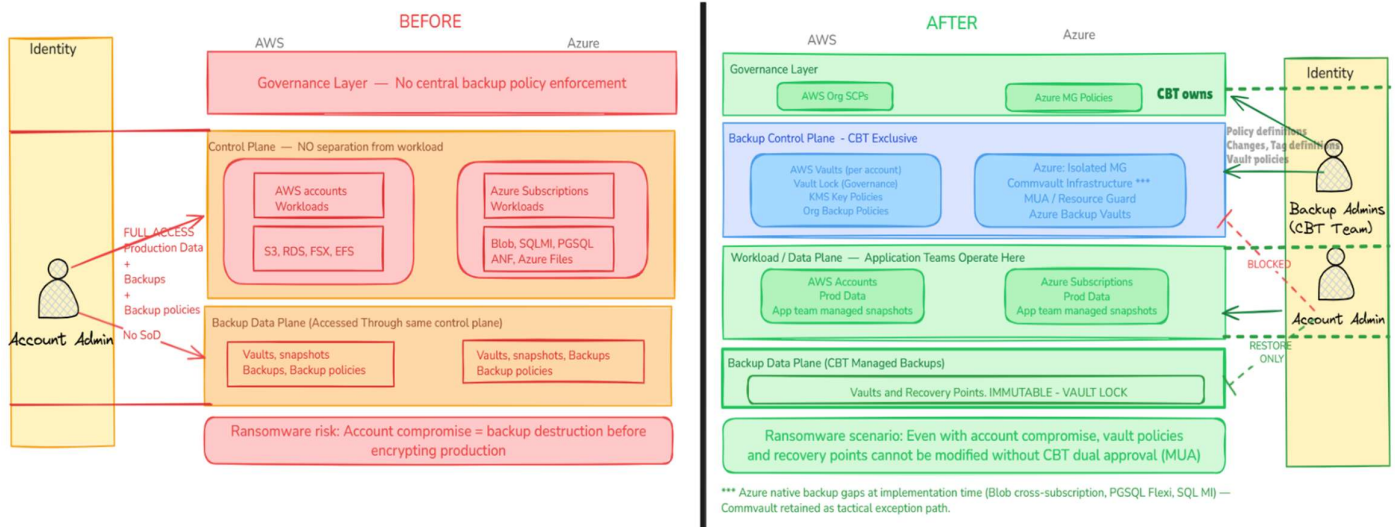
- All destructive backup operations on Azure now require dual approval - a workload admin or even a compromised operator account cannot unilaterally destroy backups.
- CBT owns the Resource Guard, making them the second mandatory approvers for any vault deletion or policy modification.
- Operational overhead is minimal for legitimate recovery workflows - Resource Guard approvals are scoped to destructive operations, not routine backup and restore
- This, combined with the management group separation in Decision 4, brought Azure Commvault backups to structural CPS234 compliance.
- Residual risk of governed limited Global Administrator's elevated privileges would be controlled via PIM and activity audited.

Architecture

Noteworthy architectural elements:

1. Backup Control plane separation with exclusive access to CBT.
2. SCP and Management group policies specific to backup data and control planes.
3. MUA in Azure to protect critical vault operations via resource guard.
4. Native backup in AWS vs (tactical) Commvault in Azure, with native Azure backup as the target state as service gaps are addressed by Microsoft.
5. Self-service restores workflows unchanged for account admins/teams.

Backup Governance Architecture: Before vs After CPS 234 Compliance



Outcome

The data protection platform brought 350+ accounts and subscriptions into CPS 234 compliance within the required timeline. More than five petabytes of regulated data were protected under centralised backup governance. The architecture structurally eliminated the primary ransomware attack vector, which is destruction of backups before encrypting production, by ensuring no single compromised identity could modify or delete recovery points without CBT dual approval. Application team self-service recovery workflows remained unchanged throughout. The fragmented, workload-owned backup model was replaced with automated onboarding, offboarding, monitoring and auditability at scale.

The centralised vault (3-2-1 bunker) remains the architectural target state – an air-gapped final recovery layer to be implemented as a subsequent programme phase.

References

APRA: <https://www.apra.gov.au/security-and-adequacy-of-backups#:~:text=Maintain%20sufficient%20isolation%20of%20backups,2024>

Commvault: <https://documentation.commvault.com>

AWS Backup: <https://docs.aws.amazon.com/aws-backup/latest/devguide/whatisbackup.html>

Vault Lock: <https://docs.aws.amazon.com/aws-backup/latest/devguide/vault-lock.html>

MUA / Resource Guard: <https://learn.microsoft.com/en-us/azure/backup/multi-user-authorization-concept>

AWS KMS Key Policies: <https://docs.aws.amazon.com/kms/latest/developerguide/key-policies.html>